Report di Penetration Testing: Vulnerabilità MS17-010

1. Executive Summary

Obiettivo: Testare la sicurezza del notebook target (IP: 192.168.1.13) verificando la presenza della vulnerabilità MS17-010 (EternalBlue).

Risultato: La vulnerabilità tramite exploit diretto è risultata mitigata dalle patch di sistema, ma l'accesso è stato ottenuto con successo tramite un payload personalizzato (MSFVenom), dimostrando la possibilità di controllo remoto totale.

2. Metodologia e Fasi dell'Attacco

A. Information Gathering (Scansione)

L'attività è iniziata con una scansione delle porte tramite Nmap.

Comando: nmap -p 445 192.168.1.13

Risultato: La porta 445 (SMB) è risultata inizialmente filtered, poi aperta (open) dopo la configurazione del firewall.

B. Analisi delle Vulnerabilità

È stato tentato l'exploit MS17-010 (EternalBlue) tramite Metasploit.

Modulo: exploit/windows/smb/ms17_010_eternalblue

Esito: Fallito. Il sistema target è risultato aggiornato con le patch di sicurezza correnti, rendendo il kernel non vulnerabile al buffer overflow specifico.

C. Exploitation (Accesso)

Per superare le restrizioni, è stato creato un payload Reverse TCP.

Strumento: msfvenom

Payload: windows/x64/meterpreter/reverse_tcp

Esecuzione: Il file è stato eseguito sul target, stabilendo una connessione verso la macchina attaccante (Kali Linux).

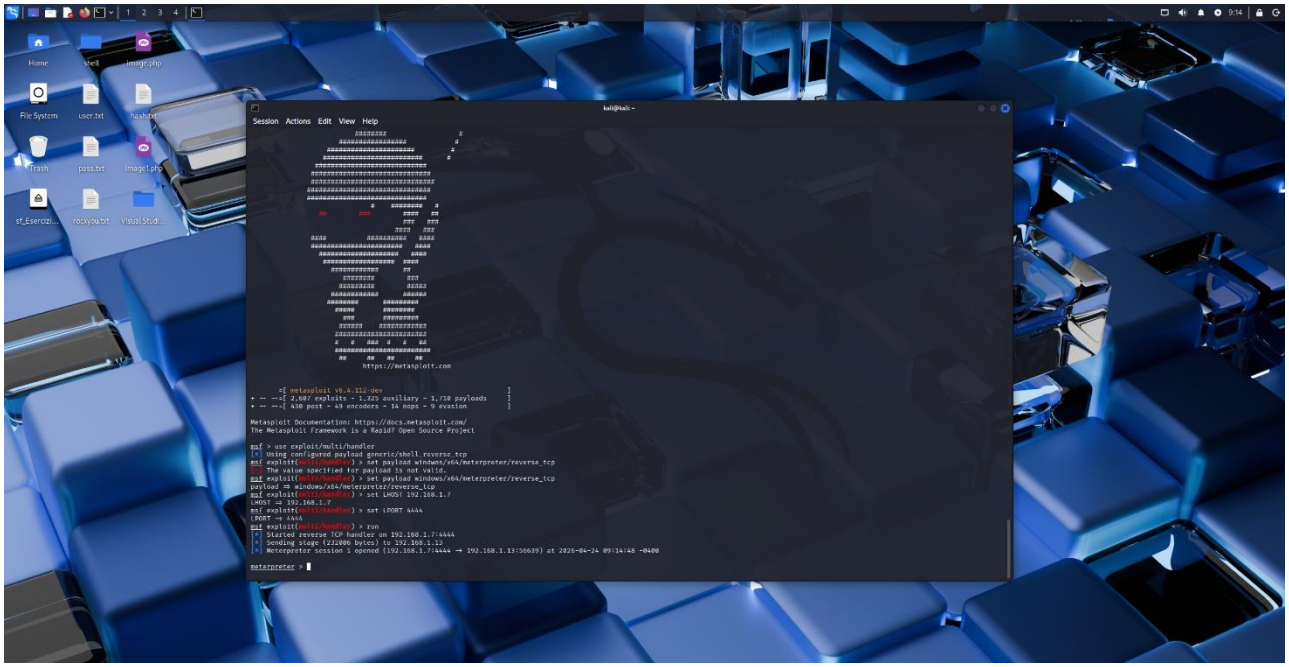
3. Post-Exploitation (Prove del controllo)

Una volta ottenuta la sessione Meterpreter, sono state eseguite le seguenti operazioni come prova del compromesso

Screenshot dello schermo: Acquisizione dell'attività in tempo reale dell'utente.

Accesso Webcam: Scatto fotografico tramite la periferica integrata (webcam_snap).

Keylogging: Intercettazione dei tasti premuti dall'utente per il recupero di informazioni sensibili.



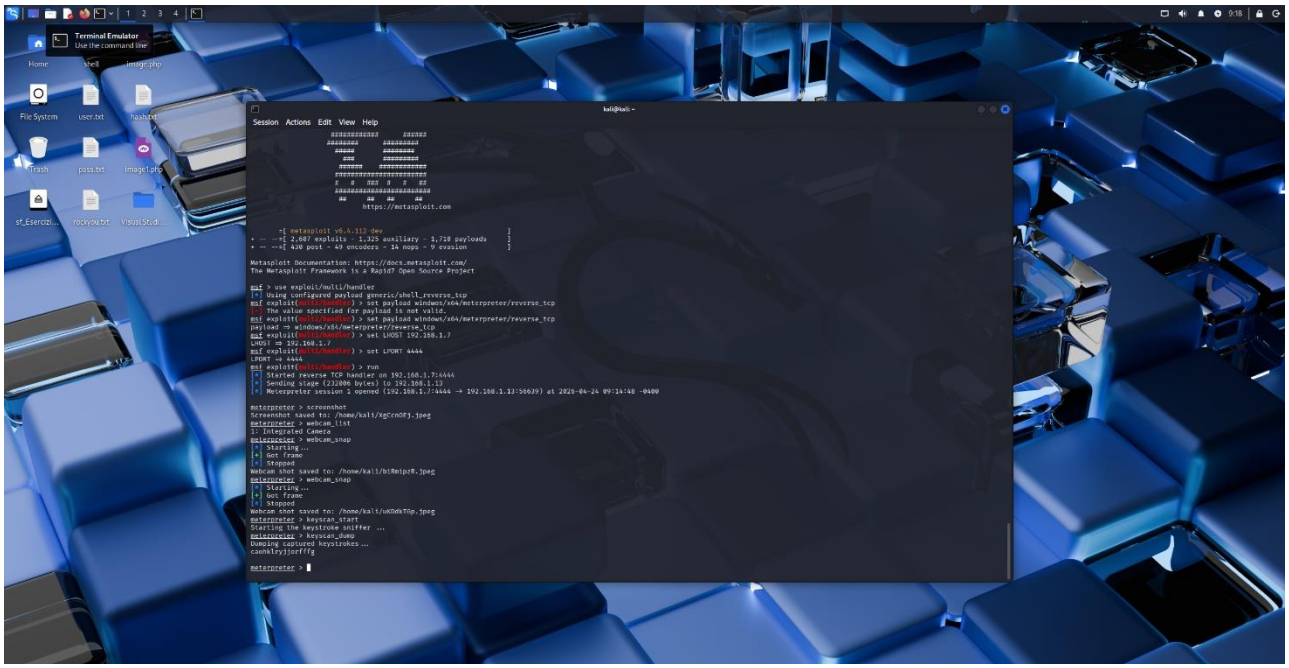
4. Mitigazione e Rimedio (Remediation)

Per mettere in sicurezza il sistema, sono state consigliate e applicate le seguenti misure:

Aggiornamento del Sistema: Installazione delle patch critiche (KB4012212 e successive).

Disabilitazione SMBv1: Rimozione del protocollo obsoleto dalle "Funzionalità Windows".

Configurazione Endpoint: Riattivazione di Windows Defender e del Firewall per bloccare l'esecuzione di file non autorizzati



REPORT DI PENETRATION TESTING: ENUMERAZIONE MYSQL

1. Informazioni Generali

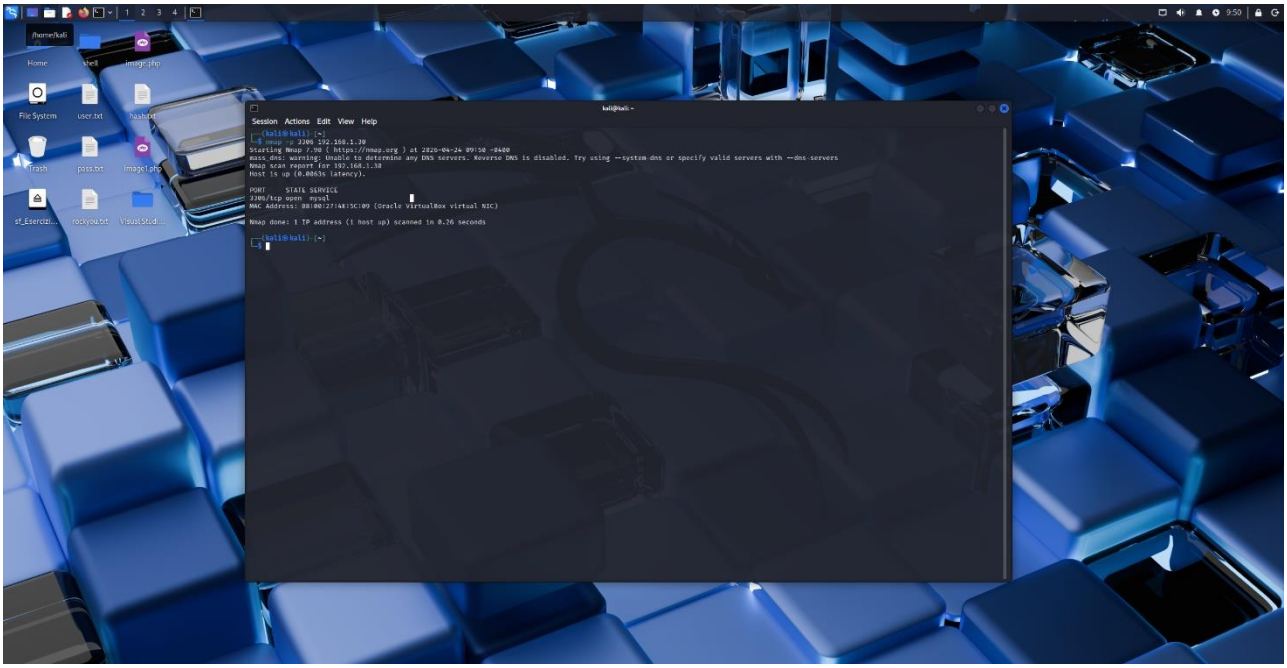
- **Data:** 24 Aprile 2026
- **Target (Vittima):** 192.168.1.30 (Metasploitable 2)
- **Attaccante:** 192.168.1.25 (Kali Linux)
- **Vettore di attacco:** Database Service (Port 3306)

---

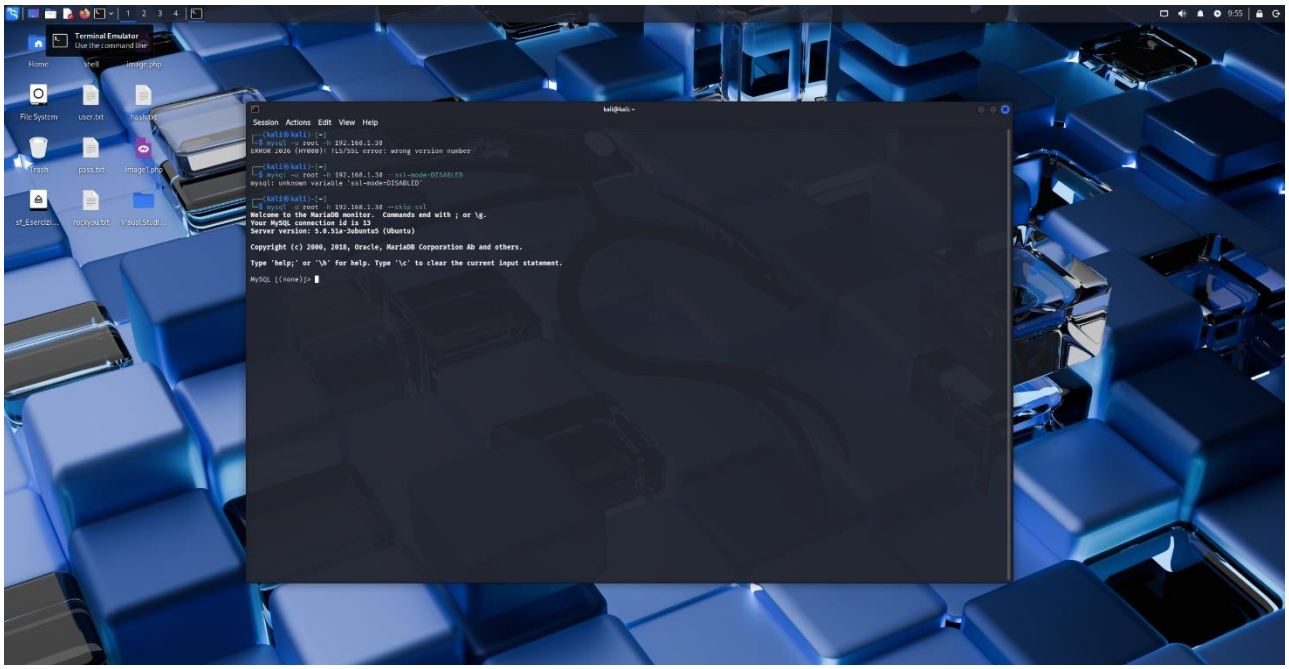
2. Metodologia di Analisi

L'attività è stata suddivisa in tre fasi principali:

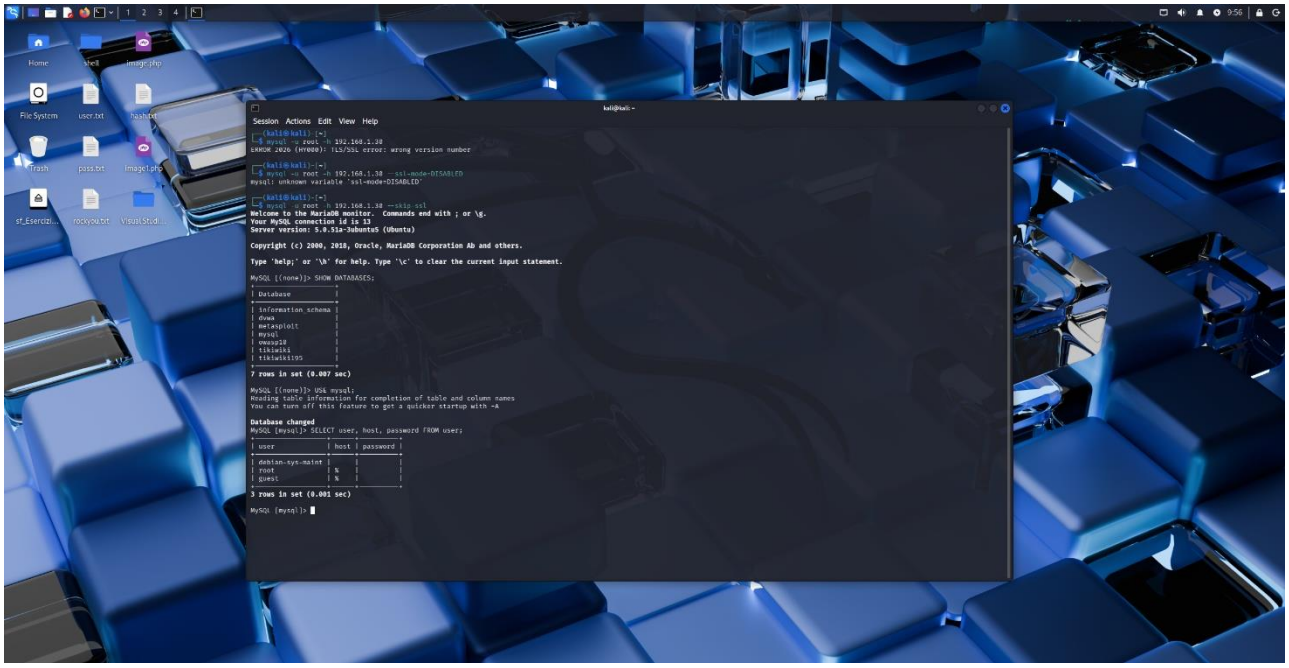
1. **Scanning:** Identificazione del servizio attivo.



2. **Brute-forcing:** Tentativo fallito di enumerazione automatizzata tramite script Nmap (causa: incompatibilità protocolli).



3. **Exploitation:** Accesso manuale sfruttando l'assenza di password sull'utente root e forzando la disattivazione del protocollo SSL.



---

3. Evidenze Tecniche (Risultati)

Tramite accesso diretto al database di sistema mysql, è stata estratta la lista degli account presenti.

Comando utilizzato:

SQL

SELECT user, host, password FROM user;

Tabella Utenti Identificati:

Username	Host	Stato Credenziali
root	localhost / %	**Vulnerabile** (Nessuna password)
debian-sys-maint	localhost	Password Hash presente
guest	%	Accesso limitato

---

4. Analisi delle Vulnerabilità Rilevate

VULN-01: Autenticazione Root Nulla

L'utente amministratore (root) non possiede una password. Questo permette a chiunque abbia visibilità di rete sul server di prendere il controllo totale del database.

VULN-02: Configurazione SSL Obsoleta

Il server non supporta connessioni cifrate moderne, forzando la trasmissione dei dati in chiaro (Plain Text). Un utente malintenzionato potrebbe intercettare le sessioni tramite attacchi di tipo *Man-in-the-Middle* (MITM).

VULN-03: Esposizione Remota dell'Interfaccia di Gestione

Il servizio MySQL è in ascolto su tutte le interfacce di rete, non limitando l'accesso al solo localhost.

---

5. Raccomandazioni (Remediation)

1. **Impostare Password forti:** Eseguire il comando SET PASSWORD FOR 'root'@'%' = PASSWORD('StrongPassword123!');.
2. **Limitare gli Host:** Modificare la colonna host per l'utente root in modo che possa connettersi solo da IP fidati o solo da localhost.
3. **Aggiornamento Software:** La versione di MySQL rilevata è obsoleta e non supporta standard di sicurezza moderni. Si consiglia la migrazione a una versione supportata.
4. **Firewalling:** Bloccare la porta 3306 a livello di rete, permettendo l'accesso solo ai server applicativi autorizzati.